

Manual 16 — Implementación Controlada ISO/IEC 27001 / 27002

Edición controlada es-419 — candidata de desarrollo

****Orden de la serie:**** 16

****Fuente inglesa congelada:**** `controlled/en/MANUAL\_16\_CONTROLLED\_EN.md`

****SHA de blob fuente:**** `0a4d1e84cf4844be1685287a441392b7a1fa6c25`

****Línea base autoritativa:**** ISO/IEC 27001:2022; ISO/IEC 27001:2022/Amd 1:2024; ISO/IEC 27002:2022

Límite de publicación y estándares

Este es un manual independiente de implementación. No es una publicación de ISO, no reproduce texto protegido de cláusulas o controles ISO/IEC, no otorga certificación y no sustituye las normas licenciadas. ISO/IEC 27001 contiene requisitos para un SGSI; ISO/IEC 27002 proporciona orientación para implementar controles. Las decisiones sobre Declaración de Aplicabilidad, tratamiento de riesgos, auditoría, certificación y conformidad dependen del contexto y requieren evidencia competente y juicio profesional adecuado.

Capítulo 1 — Propósito, gobierno y modelo operativo del SGSI

Defina por qué existe el SGSI, qué resultados del negocio protege y cómo el gobierno convierte objetivos de seguridad en decisiones operativas con responsables claros. Asigne patrocinador ejecutivo, propietario del SGSI, propietarios de riesgo, propietarios de controles y custodios de evidencia. Conserve carta de gobierno, política aprobada, asignaciones de rol y registros de decisiones.

Capítulo 2 — Contexto organizacional y partes interesadas

Identifique condiciones internas y externas que puedan afectar los resultados de seguridad. Mantenga un registro de contexto que incluya estrategia, tecnología, proveedores, obligaciones legales, amenazas y condiciones físicas materiales. Determine partes interesadas relevantes y sus requisitos. Documente la consideración de relevancia climática sin asumir que siempre es material.

Capítulo 3 — Alcance y límites del SGSI

Defina un alcance comprensible, defendible y real desde el punto de vista operativo. Identifique entidades, servicios, ubicaciones, aplicaciones, nube, redes, personas, proveedores y flujos de información incluidos. Registre interfaces, dependencias y exclusiones justificadas y concilie el alcance con inventarios y arquitectura.

Capítulo 4 — Liderazgo, política y rendición de cuentas

La alta dirección debe establecer dirección, aprobar la política de seguridad, asignar responsabilidades y asegurar recursos y autoridad suficientes. Convierta compromisos de

liderazgo en objetivos medibles y decisiones de gobierno. Conserve evidencia de aprobaciones, revisiones ejecutivas, recursos y riesgos residuales aceptados.

Capítulo 5 — Roles, responsabilidades y segregación

Documente quién posee riesgos, opera controles, revisa evidencia, aprueba excepciones y realiza aseguramiento independiente. Evite combinaciones incompatibles de acceso, aprobación y revisión cuando generen riesgo inaceptable. Mantenga y revise una matriz de responsabilidades.

Capítulo 6 — Metodología de evaluación de riesgos

Defina criterios repetibles para identificar, analizar y evaluar riesgo de seguridad de la información. Especifique activos o servicios, amenazas y vulnerabilidades, escalas de probabilidad e impacto, controles existentes, riesgo inherente y residual, autoridad de aceptación y disparadores de reevaluación.

Capítulo 7 — Tratamiento y aceptación del riesgo

Para cada riesgo material, seleccione una estrategia de tratamiento, vincule acciones con objetivos de control, responsables, fechas y evidencia, y evalúe explícitamente el riesgo residual. La aceptación debe realizarla una autoridad definida y los planes deben seguirse hasta su cierre.

Capítulo 8 — Gobierno de la Declaración de Aplicabilidad

Use la Declaración de Aplicabilidad como registro de gobierno que vincula riesgos y obligaciones con los controles necesarios. No trate el Anexo A como una lista universal obligatoria. Registre razones de inclusión o exclusión, estado de implementación y vínculos a evidencia.

Capítulo 9 — Objetivos de seguridad y planificación

Defina objetivos medibles alineados con política y contexto. Cada objetivo debe tener propietario, métrica, meta, frecuencia o fecha y fuente de evidencia. Use indicadores que ayuden a tomar decisiones y revisar desempeño real.

Capítulo 10 — Recursos, competencia y concienciación

Identifique personas, presupuesto, herramientas, infraestructura y conocimientos necesarios. Defina requisitos de competencia por rol y conserve evidencia apropiada. La concienciación debe cubrir políticas, conducta esperada, reporte de incidentes y obligaciones específicas del rol.

Capítulo 11 — Comunicaciones e información documentada

Defina qué información de seguridad debe comunicarse, a quién, cuándo y por qué canal. Controle documentos y registros mediante propiedad, versión, aprobación, retención y acceso. Distinga registros autoritativos de notas de trabajo.

Capítulo 12 — Planificación y control operacional

Convierta decisiones de tratamiento en procedimientos repetibles con disparadores, responsables, frecuencia, evidencia, manejo de excepciones y escalamiento. Integre los controles con gestión de cambios, servicios, ingeniería y operaciones normales.

Capítulo 13 — Gobierno de activos y clasificación de información

Mantenga inventarios actuales de información, sistemas, servicios, dispositivos, repositorios y dependencias críticas. Asigne propiedad y clasificación según sensibilidad, obligaciones y impacto. Defina reglas de manejo, almacenamiento, transmisión, retención y eliminación.

Capítulo 14 — Gestión de identidad y acceso

Defina el ciclo de vida de identidades desde incorporación hasta baja. Aplique mínimo privilegio, acceso acorde al rol, revisiones periódicas y revocación oportuna. Separe identidades de usuario, servicio y privilegio y conserve trazabilidad de las decisiones.

Capítulo 15 — Acceso privilegiado y autenticación

Aplique gobierno reforzado a accesos administrativos y de alto impacto. Use controles de autenticación apropiados, limite privilegios permanentes cuando sea viable, supervise actividad privilegiada y revise accesos de emergencia. Gestione excepciones con planes aprobados.

Capítulo 16 — Criptografía y gestión de claves

Defina cuándo se requiere protección criptográfica según riesgo, obligaciones y clasificación. Governe algoritmos, protocolos, certificados y ciclo de vida de claves, incluyendo generación, almacenamiento, rotación, respaldo, revocación y destrucción.

Capítulo 17 — Seguridad física y ambiental

Proteja instalaciones, equipos y medios según criticidad y riesgo. Defina autorización de acceso físico, visitantes, monitoreo, áreas seguras, controles ambientales y eliminación de equipos y medios. Conserve registros y resultados de revisión.

Capítulo 18 — Operaciones, registros y monitoreo

Establezca procedimientos operativos controlados. Defina requisitos de logging, sincronización de tiempo, protección de registros, casos de uso de monitoreo, responsables, retención y escalamiento. Pruebe que eventos críticos se generan, conservan y pueden revisarse.

Capítulo 19 — Gestión de vulnerabilidades y configuración

Mantenga líneas base seguras y un proceso repetible para identificar, priorizar y remediar vulnerabilidades. Use riesgo, explotabilidad, exposición y criticidad para priorizar. Governe excepciones con justificación, controles compensatorios, responsable y expiración.

Capítulo 20 — Desarrollo seguro y gestión de cambios

Integre seguridad en adquisición, desarrollo y cambio. Defina revisión de arquitectura, código o configuración, pruebas, dependencias, secretos y aprobación de liberación según riesgo. Vincule cambios materiales con reevaluación de riesgos y evidencia.

Capítulo 21 — Seguridad de proveedores y terceros

Clasifique proveedores por acceso a información, criticidad, conectividad y concentración. Defina debida diligencia, requisitos contractuales, monitoreo continuo, notificación de incidentes, subcontratación y terminación. Haga seguimiento de hallazgos hasta su remediación.

Capítulo 22 — Nube y responsabilidad compartida

Documente el modelo de responsabilidad compartida para cada servicio en nube y asigne responsabilidades a propietarios reales. Governe identidades, configuración, cifrado, logging, redes, resiliencia y respaldos. No asuma que la certificación del proveedor elimina responsabilidades del cliente.

Capítulo 23 — Gestión de incidentes y evidencia

Defina preparación, detección, triaje, contención, erradicación, recuperación, comunicación y lecciones aprendidas. Establezca severidad, roles, escalamiento y reglas de preservación de evidencia. Retroalimente causas raíz y fallas de control al proceso de riesgo y acción correctiva.

Capítulo 24 — Continuidad y resiliencia

Identifique dependencias de seguridad que soportan servicios críticos. Defina objetivos de recuperación, respaldos, alternativas, comunicaciones y requisitos de seguridad durante interrupciones. Pruebe escenarios y remedie debilidades documentadas.

Capítulo 25 — Interfaces de privacidad y regulación

Identifique dónde privacidad, regulación sectorial, compromisos contractuales o leyes locales afectan controles del SGSI. Mantenga un registro de obligaciones, asigne responsables y vincule obligaciones con políticas, riesgos, controles, evidencia y monitoreo.

Capítulo 26 — Monitoreo, medición y efectividad de controles

Defina métricas que muestren si el SGSI y sus controles funcionan como se espera. Cada métrica debe tener propietario, regla de cálculo, fuente, meta y umbral. Combine indicadores cuantitativos con pruebas específicas de control y análisis de tendencias.

Capítulo 27 — Preparación para auditoría interna

Mantenga un programa de auditoría basado en alcance, riesgo, hallazgos previos y cambios materiales. Asegure objetividad y competencia suficientes. Defina criterios, población, muestreo, evidencia, hallazgos y seguimiento y conserve papeles de trabajo reproducibles.

Capítulo 28 — Revisión por la dirección

Proporcione a liderazgo una revisión estructurada de idoneidad, adecuación y eficacia del SGSI. Incluya resultados de auditoría, objetivos, riesgos, incidentes, proveedores, recursos, desempeño de controles, cambios y oportunidades de mejora. Registre decisiones y acciones.

Capítulo 29 — No conformidad, acción correctiva y remediación

Cuando no se cumplan requisitos o procesos aprobados, registre el problema, contenga efectos, identifique causa raíz, defina acción correctiva, asigne responsable y verifique efectividad. No cierre hallazgos solo porque exista un plan.

Capítulo 30 — Mejora continua y disparadores de cambio

Use incidentes, auditorías, métricas, cambios tecnológicos, inteligencia de amenazas, cambios de negocio y lecciones aprendidas para mejorar el SGSI. Defina disparadores formales de reevaluación para fusiones, productos, nube, proveedores críticos, incidentes y cambios regulatorios.

Capítulo 31 — Arquitectura de evidencia, rutas de implementación y madurez

Para cada objetivo material, mantenga una cadena trazable: requisito o riesgo, objetivo de control, actividad, propietario, frecuencia o disparador, fuente de evidencia, revisor, excepción y disparador de cambio. Distinga evidencia de diseño de evidencia operativa.

Capítulo 32 — Liberación, localización, procedencia y reevaluación

La edición es-419 deriva exclusivamente de la fuente inglesa congelada identificada arriba. Antes de publicar, verifique paridad estructural y semántica, genere DOCX/PDF, ejecute QA de contenido, renderizado, accesibilidad y revisión visual, registre SHA-256, procedencia y resultados de workflows y coloque los binarios exactos en `main` antes de promover catálogo o registro de liberación.

Modelo de evidencia controlada

contexto/requisito → riesgo → objetivo de control → actividad de implementación → propietario → frecuencia/disparador → población → evidencia → prueba/revisión → excepción/remediación → disparador de reevaluación